

Red-Team Assessment Report

External black-box adversary emulation • wintergate.org

TARGET

wintergate.org + subdomains

ENGAGEMENT

External black-box

TESTER

anonymoussrmrf

TEST DATE

2026-07-11

AUTHORIZATION

Owner-authorized (verbal)

TESTING IP

159.26.108.2

1. Executive Summary

wintergate.org was assessed as an unprivileged external attacker with no prior access, credentials, or allowlisting. The objective was to determine whether an internet-based adversary could reach or compromise the web infrastructure.

Overall result: the external perimeter is well-defended. Every internet-facing host sits behind Cloudflare with an active JavaScript Managed Challenge, TLS/JA3 fingerprinting, and rate limiting. In combination these controls blocked all automated reconnaissance and scanning attempted during the engagement, and the rate limiter actively issued a temporary ban (Cloudflare Error 1015) in response to aggressive traffic. No origin server IP was exposed, no wildcard DNS misconfiguration was present, and no exploitable vulnerability was confirmed.

The application layer behind the challenge (authentication flows on id.wintergate.org, API surface on api.wintergate.org) was **not** reached during this window and remains untested. A patient human attacker using a real browser could still interact with those surfaces; that testing is recommended as a follow-up.

0

CONFIRMED
EXPLOITABLE

Low

HIGHEST SEVERITY

3

LIVE HOSTS (ALL
FRONTED)

Strong

PERIMETER POSTURE

2. Scope and Rules of Engagement

Item	Detail
In-scope	wintergate.org, all subdomains and directories
Out-of-scope	Any other domain or third-party service
Authorization	Owner-authorized, verbal
Aggression	Full permitted; testing from tester's own source IP
Identifying header	X-Bug-Bounty: anonymousr m r f on active traffic
Testing IP	159.26.108.2

Note. Authorization for this engagement was verbal. A written authorization letter (scope, dates, tester identity) is recommended for the tester's and owner's protection on any future testing.

3. Methodology

Testing followed a passive-to-active progression, mapped to MITRE ATT&CK tactics.

Phase	ATT&CK Tactic	Activity
Passive OSINT	Reconnaissance (TA0043)	Certificate transparency, DNS records, subdomain enumeration, historical IP lookup
Live-host probing	Reconnaissance (TA0043)	HTTP fingerprinting, tech/CDN/WAF detection, CNAME analysis
Origin discovery	Reconnaissance (TA0043)	Historical DNS, candidate-subdomain resolution, cert-based origin search
Initial access attempts	Initial Access (TA0001)	Automated scanning, challenge-solving via headless browser, TLS-fingerprint impersonation

Tooling: subfinder, httpx, katana, feroxbuster, nuclei, dnsx, FlareSolv~~e~~r, plus native DNS and HTTP clients.

4. Attack-Surface Map

Host	Resolves	Fronting	Status	Notes
www.wintergate.org	Cloudflare	Cloudflare	403 Managed Challenge	Primary web app
api.wintergate.org	Cloudflare	Cloudflare	403 Managed Challenge	API surface
id.wintergate.org	Cloudflare	Cloudflare	403 Managed Challenge	Identity / authentication
db.wintergate.org	No DNS record	n/a	n/a	Certificate in CT logs; no current A/AAAA (decommissioned)

Infrastructure: Cloudflare DNS/CDN/WAF (nameservers aurora / bob .ns.cloudflare.com); email via Mailgun (`v=spf1 include:mailgun.org ~all`); no wildcard DNS; small attack surface (three live subdomains).

5. Findings

F-01

POSITIVE

External perimeter defenses validated as effective

The following controls were observed and confirmed to function as intended against an external attacker:

- **Cloudflare Managed Challenge (JS interstitial)** on all live hosts, blocking headless and CLI reconnaissance tooling (nuclei, ffuf, katana, httpx), which received only the challenge page.
- **TLS / JA3 fingerprinting.** Attempts to replay a browser-solved `cf_clearance` cookie from non-browser clients failed; Cloudflare re-challenged requests whose TLS fingerprint did not match the solving browser.
- **Rate limiting.** Aggressive request volume triggered HTTP 429, followed by a temporary IP ban (Cloudflare Error 1015).

Assessment: these layered controls make bulk automated attack against the perimeter impractical. This is a strength and should be maintained.

F-02 LOW DMARC policy set to `quarantine` rather than `reject`

Observed: `_dmarc.wintergate.org` → `v=DMARC1; p=quarantine; rua=mailto:dmarc@wintergate.org; pct=100; ri=86400`. SPF present with soft-fail: `v=spf1 include:mailgun.org ~all`.

Impact: the domain is reasonably protected against spoofing (DMARC enforcing at 100%). Because policy is `quarantine`, a spoofed message is quarantined rather than rejected outright, leaving a narrow residual spoofing/phishing risk.

Recommendation: after confirming legitimate mail passes, move to `p=reject`; consider tightening SPF from `~all` to `-all` once all senders are accounted for.

F-03 INFORMATIONAL Stale certificate for `db.wintergate.org` in CT logs

`db.wintergate.org` appears in certificate transparency logs but has no current DNS record.

Impact: minor internal-naming disclosure; no current exposure. If the DNS record is ever re-created pointing at an unclaimed resource, it could become a subdomain-takeover candidate.

Recommendation: ensure decommissioned hosts have no lingering DNS delegations; monitor CT logs.

F-04 INFORMATIONAL No CAA record present

No CAA record was returned for `wintergate.org`.

Impact: any certificate authority can issue certificates for the domain. Low risk given Cloudflare-managed TLS, but a CAA record reduces mis-issuance risk.

Recommendation: publish a CAA record restricting issuance to the CAs actually in use.

6. Origin Exposure Assessment

A key attacker goal against a Cloudflare-fronted site is locating the origin server IP to bypass the CDN/WAF. This was investigated and **the origin was not exposed**:

- Historical DNS (ViewDNS) showed only two Cloudflare IPs plus a single 2020-era GoDaddy shared-hosting IP (184.168.221.35), which no longer responds on ports 80/443.
- Shodan domain data returned only Cloudflare IPs for `www`, `api`, and `id`.

- Guessed origin/bypass subdomains (dev, staging, admin, origin, mail, direct, etc.) do not resolve; no wildcard exists.

Assessment: no origin-IP leak identified; the CDN/WAF cannot be trivially bypassed via origin discovery.

7. What Was Not Tested (Limitations)

This was a time-boxed external test. The following were **not** assessed and remain open:

- **Application-layer testing** of www, api, id behind the challenge: authentication flows, session management, JWT/OAuth handling, IDOR/BOLA, injection, XSS, business logic.
- **Authenticated testing:** no accounts were provisioned; no authorization/tenancy testing performed.
- **API contract review:** no OpenAPI/Swagger/GraphQL schema was retrieved.

The perimeter's strength against automation does not by itself indicate the application behind it is secure; it only means an attacker must slow down and act like a human to reach it.

8. Recommendations (Prioritized)

1. **Maintain the current Cloudflare posture** (Managed Challenge, Bot Fight Mode, rate limiting). It is effective against automated attack.
2. **Commission follow-up application-layer testing** of id/api/www via authenticated, human-paced manual testing. This is where real-world risk most likely resides and it was out of reach this window.
3. **Move DMARC to** `p=reject` and tighten SPF to `-all` once mail streams are verified (F-02).
4. **Publish a CAA record** (F-04).
5. **Hygiene:** confirm decommissioned hosts (db) have no exploitable residual DNS; monitor CT logs (F-03).
6. **Formalize authorization** in writing for any future engagement.

9. Appendix: Key Evidence

- DNS: apex A/AAAA on Cloudflare; NS aurora/bob.ns.cloudflare.com; MX/SPF via Mailgun.
- DMARC: `v=DMARC1; p=quarantine; pct=100` .
- Live hosts (www, api, id): HTTP 403, title "Just a moment...", Server: cloudflare, HTTP/3, HSTS.

- Rate-limit ban: Cloudflare Error 1015, Ray ID a194a3eccfb4349b, 2026-07-11 03:14:51 UTC, source 159.26.108.2.
- Historical IPs (ViewDNS): 172.67.153.40 (CF), 104.21.32.173 (CF), 184.168.221.35 (GoDaddy, 2020, dead).

Report prepared 2026-07-11. External black-box adversary emulation, point-in-time. Absence of confirmed vulnerabilities reflects the limited external-perimeter scope reached, not a guarantee of application security.